

Thesis Questions:

1. Explain your thesis in two minutes.

Strong answer

"My thesis evaluates how effectively Large Language Models, specifically ChatGPT and Llama 3.1, perform architecture-level threat modelling compared with classical tools such as Microsoft Threat Modeling Tool and OWASP Threat Dragon. Three standardized scenario packages were created and used as identical inputs for all approaches. Independent STRIDE-based Reference Threat Models were then developed as benchmarks. Finally, all generated threats are evaluated using predefined metrics such as coverage, precision, and evidence grounding."

2. Why did you choose this topic?

Answer:

AI is increasingly being used in software engineering, but there is limited empirical evidence on how reliable it is for architecture-level threat modelling. My research investigates whether AI can complement or improve existing approaches through a structured comparison.

3. Why architecture-level instead of source code?

This question is almost certain.

Answer:

Threat modelling is intended to be performed during the software design phase. Architecture-level analysis allows every approach to receive the same information before implementation, ensuring a fair and reproducible comparison.

4. Why did you create the Scenario Packages?

Answer:

They standardize the experimental input. Every evaluated approach receives exactly the same architecture, DFD, assets, entry points, and trust boundaries. This removes input bias.

5. How did you build the Reference Threat Models?

Very important.

Answer:

I systematically analysed each architecture using STRIDE. I examined every component, data flow, data store, external entity, and trust boundary. Candidate threats were reviewed, duplicates removed, unsupported assumptions excluded, and the resulting benchmark frozen before evaluating any tool outputs.

6. How do you know your Reference Model is correct?

Answer:

I do not claim it is universally complete. It is an expert-derived benchmark created using a documented and repeatable process. Its purpose is to provide a consistent basis for comparing different approaches.

7. Why didn't you use Microsoft TMT as the benchmark?

Answer:

Microsoft TMT is one of the evaluated tools. Using it as the benchmark would bias the comparison. The benchmark must be independent.

8. Why did you choose STRIDE?

Answer:

STRIDE is one of the most established threat modelling methodologies for architecture-level analysis. It directly maps to architectural elements such as processes, data flows, and trust boundaries.

9. Why only three scenarios?

Answer:

Three scenarios provide sufficient architectural diversity while keeping the experiment manageable and ensuring consistent evaluation across all approaches.

10. Why ChatGPT and Llama?

Answer:

They represent two widely used LLM categories: proprietary and open-source. Comparing both provides broader insight into AI-assisted threat modelling.

11. Why two outputs from each LLM?

Answer:

To evaluate response consistency and understand whether repeated executions produce similar threat models.

12. How did you ensure fairness?

Answer:

Every approach received the same scenario package, the same architectural information, and was evaluated against the same independent reference model using identical criteria.

13. What metrics will you calculate?

Answer:

Mention only the metrics from your approved methodology.

Example:

- Coverage
- Precision
- Evidence Grounding
- False Positives
- False Negatives

Don't invent additional metrics during the viva.

14. What is your research contribution?

Answer:

A reproducible benchmarking methodology that compares AI-assisted and classical threat modelling approaches using standardized scenario packages and independent reference threat models.

15. What limitations does your study have?

Answer:

The scenarios are architecture-level and intentionally technology-neutral. The benchmark reflects expert judgement, and the findings may not directly generalize to every real-world software system.

16. Suppose ChatGPT identifies a valid threat missing from your Reference Model. What happens?

Excellent question.

Answer:

I would document it as a disagreement between the benchmark and the tool. If subsequent review confirms that the benchmark missed a legitimate architecture-level threat, this would be discussed transparently as a limitation rather than silently changing the benchmark.

17. How can another researcher reproduce your work?

Answer:

By using the same scenario packages, prompts, reference models, evaluation criteria, and scoring methodology.

18. Why use architecture diagrams and DFDs?

Answer:

They provide the structural information required for architecture-level threat modelling and are the common input for both AI and classical tools.

19. What was the hardest part of this thesis?

This is where you demonstrate ownership.

A genuine answer could be:

"Developing the Reference Threat Models was the most challenging part because they had to be independent, internally consistent, and detailed enough to serve as a benchmark. Defining threats without introducing implementation assumptions required several rounds of review."

That answer reflects the work you've actually done.

20. How can I be confident this is your work?

This is the question behind many supervisor conversations.

A good response is:

"I can explain and justify every methodological decision in the thesis—from the design of the scenario packages and the application of STRIDE to the construction of the reference models and the evaluation criteria. I also maintained intermediate artifacts such as scenario packages, reference models, review logs, and revision history. Those documents show how the benchmark evolved before any comparisons were performed."

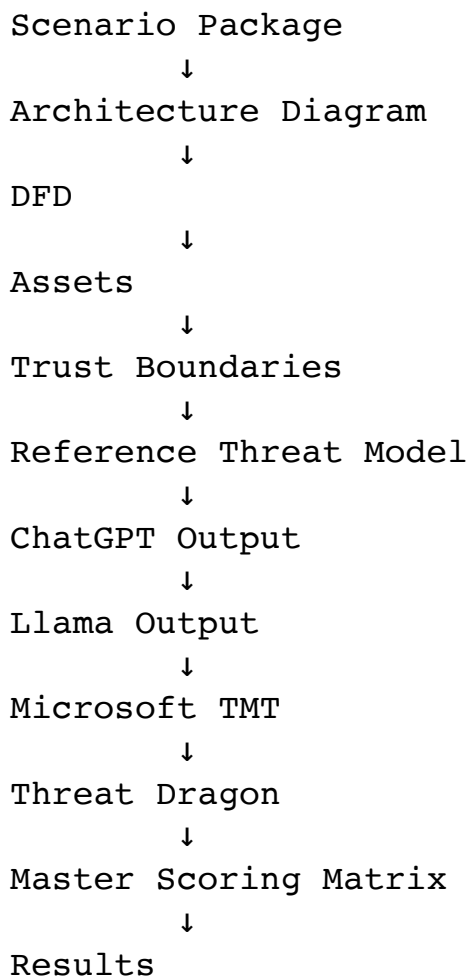
1. Show me one complete workflow for Scenario 1.

This is probably the **most likely question**.

Your supervisor may say:

"Forget the thesis. Show me exactly how Scenario 1 went from description to evaluation."

You should be able to explain:



If you can explain this smoothly, your supervisor will immediately see that you understand the research process.

2. Why do you need a Reference Threat Model?

They may ask:

"Why can't you just compare ChatGPT with Microsoft TMT?"

Perfect answer:

"Because neither tool is considered ground truth. An independent benchmark is required so every evaluated approach is assessed against the same reference."

3. How did you ensure the Reference Model wasn't biased?

Very likely.

Answer:

"The benchmark was created before evaluating the tools, using a documented STRIDE-based process applied consistently across all scenarios. It was reviewed independently of the AI outputs."

4. Suppose ChatGPT identifies a threat missing from your benchmark.

What do you do?

Correct answer:

"I don't immediately modify the benchmark. I document the disagreement, review the threat against the architecture, and discuss it as part of the analysis. Any benchmark revision must be transparent."

5. Why should we trust your benchmark?

Say:

"Because the methodology is documented, reproducible, architecture-based, and independent of the evaluated tools."

Never say

"Because I know security."

6. How exactly did you apply STRIDE?

Expect this.

Explain

Component

↓

Apply STRIDE

↓

Candidate Threats

↓

Review

↓

Final Threat

Show one example.

Authentication Server

↓

Spoofing

↓

Credential Spoofing

↓

Included.

7. Why Architecture?

Your supervisor could ask

"Why not just provide text?"

Answer

"Architecture identifies the structural components while the DFD shows how information moves. STRIDE requires architectural context."

8. Why DFD?

Answer

"Many threats arise on data flows and trust boundaries. The DFD makes those visible."

9. How many trust boundaries exist?

You should know.

Not

approximately.

Exactly.

For each scenario.

10. Explain one trust boundary.

Example

Browser

↓

Server

Why?

What crosses it?

Why is it important?

11. Why only three scenarios?

Say

Different architectures

↓

Different threats

↓

Better evaluation

Not

"Because that's enough."

12. Why did you choose those scenarios?

Very likely.

Explain

Authentication

↓

File Management

↓

Password Reset

These represent different security problems.

13. Are these real applications?

Correct answer

No.

They are

architecture-level

experimental scenarios.

14. Could another researcher reproduce your work?

Answer

Yes.

Because

Scenario Packages

↓

Reference Models

↓

Prompts

↓

Outputs

↓

Evaluation

are all documented.

15. What assumptions did you make?

Mention

No implementation

No framework

No language

No deployment assumptions

Architecture only.

16. Why are implementation technologies missing?

Very likely.

Answer

To avoid introducing implementation bias.

17. What if I disagree with one of your Reference Threats?

This is a good examiner question.

Answer

"That's possible. The benchmark represents an expert-derived reference rather than an absolute truth. The important aspect is that it was developed systematically and applied consistently."

18. Why didn't you use CVSS?

Correct answer

Because

this is

threat identification

not

vulnerability scoring.

19. Why not MITRE ATT&CK?

Answer

Because

STRIDE

is intended for

architecture-level threat modelling.

MITRE ATT&CK

focuses on attacker behaviour after compromise.

20. Show me how one Reference Threat was created.

Your supervisor may literally ask this.

You should be able to open

Scenario 1



Authentication Server



Trust Boundary



STRIDE



Threat



Evidence



Reference Model

This is probably the best demonstration of your own work.

21. Why did you review and revise the benchmark?

Answer

To remove

duplicates

unsupported assumptions

inconsistencies

before freezing the benchmark.

22. What would happen if you skipped the Reference Model?

Answer

There would be

no objective benchmark.

The evaluation would become subjective.

23. Why is your methodology scientific?

Very important.

Say

Same input

↓

Independent benchmark

↓

Same evaluation criteria

↓

Reproducibility

↓

Transparent methodology

↓

Comparable results.

24. What have you completed?

Give a structured update.

✓ Proposal

✓ Literature Review

✓ Methodology

✓ Scenario Packages

✓ Architecture

✓ DFD

✓ Reference Models

✓ ChatGPT Outputs

✓ Llama Outputs

↓

Remaining

Microsoft TMT

Threat Dragon

Evaluation

Results

Discussion

25. What is your biggest risk now?

I think this is a very realistic progress meeting question.

A good answer is:

"The main remaining risk is completing the classical tool analysis and ensuring that all generated threats are consistently mapped to the reference models using the predefined evaluation criteria. Once that is complete, the remaining work is primarily analysis and writing."

That answer shows you understand where the project stands and have a realistic plan.